

Executive brief — can Halden survive a ransomware attack?

To: Managing Director · From: IT Lead · Date: 2026-10-02 · Status: for decision

This brief describes targets, not achieved results. Every "back in X" figure below is the recovery objective agreed with the business during the impact analysis. The achieved times are recorded only after a timed recovery drill has been run, and they appear in the drill report. Until then, IT will not quote a number it has not measured.

1. Where we are today (before)

Halden's current backup is a nightly copy of the file server to a **USB disk plugged into the same server**, running under a Domain Admin account. Specifically:

- **Never tested.** Nobody has ever restored anything from it. "The job ran" is not the same as "we can recover".
- **Same machine, same fate.** The backup drive is attached to the server it is meant to protect.
- **Domain Admin credentials.** If the domain is compromised, the backup is compromised with it.
- **No domain controller backup at all.** Losing AD means nobody can log in to anything.
- **No agreed targets.** We do not know how long the business can survive without the order system.

Attackers now go after the backups themselves: industry research finds backup repositories targeted in around **96% of ransomware attacks**, succeeding in about **76%** of those attempts. Our current design would be one of the successes, not the exceptions.

2. What is changing (after)

A **3-2-1-1-0** backup strategy and a tested recovery capability:

Part	Plain English
3 copies	The live data, a copy on a separate backup server, and a copy off-site
2 media	Disk storage and a second, different storage type
1 off-site	A copy outside our building, so a fire or theft does not take both
1 immutable / offline	A copy that cannot be deleted or altered , even with the backup password, plus a locked-away disk
0 errors on verified restore	We restore and check the data every week, and alert if it fails

The backup server is deliberately **not** part of the Windows domain, so an attack on the domain does not reach it. Its password and the backup encryption keys are kept separately from everyday admin accounts, with a sealed copy stored off-site in case of disaster.

3. What the business can survive — targets

These are the **objectives agreed with each department** in the impact analysis. They are what IT is now building towards and will be measured against.

Scenario	Recovery objective (target)	Data loss objective (target)
A deleted file	Restored within the working day (self-service for recent files)	None for recent files
The file server fails	Back within 4 hours	At most 1 hour of file changes
A domain controller fails	Back within 2 hours (the second controller covers most of this)	At most 24 hours
The order system fails	Back within 4 hours	At most 1 hour
Full ransomware attack, servers destroyed	Core services (AD, files, order system) back within the agreed per-system times; workstations re-imaged within 3 days	At most 1 hour of Tier 1 data

Nothing here is a measured result. Each target is proven by a **timed drill**, and any gap between the target and the actual time becomes an action with an owner and a date.

4. What IT needs from the business

1. **Sign off the targets.** The recovery objectives are a business decision, and they carry a cost: the tighter the acceptable data loss, the more often we must back up and the more storage we need. The attached service-level table is the version we are asking you to approve.

1. **Confirm the recovery order.** In a full outage we restore in dependency order — identity first, then files, then the order system, then supporting systems. Tell us if that order is wrong for the business.

1. **Name the people.** Who declares a disaster, who speaks to staff and customers, and who confirms each department's system is working before we call it recovered.

5. Proven or not — the honest position

Claim	Status
Backups are set up per the 3-2-1-1-0 design	Being built
Backups are immutable and cannot be deleted by an attacker	To be proven by a deletion test (the failure of the deletion is the evidence)
Weekly automated restore tests pass	Not yet measured — the test is built and will run weekly
Recovery times meet the targets	Not yet measured — to be proven by a timed drill
The runbook can be used by someone who did not build it	To be proven by a walkthrough

We will report the first measured results to you as soon as the drill has been run, including anything that breaks — a drill that finds problems is a drill that worked.

Halden Distribution Ltd. is a fictional company used for this portfolio project. The figures in section 3 are engineering targets agreed for the exercise, not records of a real recovery. Where a measured number is claimed on the portfolio site, it comes from a real run in the lab.

Halden Distribution Ltd. — home-lab portfolio artifact (fictional company, real configurations). Generated from p08-executive-brief.md on 2026-10-02.